



LOST BOYS CYBER

THREAT INTELLIGENCE • MALWARE ANALYSIS • DETECTION ENGINEERING



Daily 2026-10-06 Rejetto HFS CVE-2026-61500 Exploitation and File-Server Hunt

Threat Intelligence Report

Classification	TLP:CLEAR
Published	2026-10-06
Version	1.0
Author	Lost Boys Cyber
Report Type	Threat Intelligence Report

TLP:CLEAR | Lost Boys Cyber | Daily 2026-10-06 Rejetto HFS CVE-2026-61500 Exploitation and File-Server Hunt - Threat Intelligence Report

Published: 2026-10-06 | TLP:CLEAR | Version: 1.0 | Author: Lost Boys Cyber

AI Generation: This report was generated with AI assistance and is provided for informational purposes only. All findings, IOCs, detection rules, hunting queries, attribution assessments, and recommendations must be independently reviewed and validated by a qualified security professional before operational use.

Table of Contents

1. Executive Summary
2. Intelligence Metadata
3. Source Review and Confidence
4. Threat / Campaign Details
5. Attack Scenarios
6. Affected Sectors and Exposure
7. Detection Engineering
 - 7.1. Detection Logic Summary
8. Threat Hunting
 - 8.1. Microsoft Defender / KQL Hunt
9. MITRE ATT&CK Mapping
10. Incident Response and Containment
11. Recommendations
12. References

Daily 2026-10-06 Rejetto HFS CVE-2026-61500 Exploitation and File-Server Hunt

> Daily production note (2026-10-06 UTC): Selected for today's general threat coverage set from current public reporting and current defender relevance. Where same-day primary reporting was limited, the source window was expanded to the last 7 days and claims are constrained to cited sources.

1. Executive Summary

CVE-2026-61500 public exploit activity against Rejetto HFS creates a practical internet-facing file-server hunt priority, especially where small teams expose HFS for ad hoc transfer workflows.

Lost Boys Cyber selected this item because it has operational relevance, credible public sourcing, and actionable implications for vulnerability management, detection engineering, threat hunting, incident response, or sector risk reduction.

2. Intelligence Metadata

Field	Value
Daily rank	General threat report 5
Primary theme	Rejetto HFS active exploitation attempts
Sector / audience	Internet-exposed file sharing, small business IT, development teams
Published	2026-10-06
Confidence	Medium

3. Source Review and Confidence

Source	URL	Contribution
SecurityWeek Rejetto HFS exploitation coverage	https://www.securityweek.com/exploitation-hits-rejetto-hfs-vulnerability-discovered-by-ai/	Current exploitation reporting.
GitHub CVE-2026-61500 proof-of-concept repository	https://github.com/aramosf/CVE-2026-61500	Public exploit mechanics reference.
VulnCheck XDB	https://vulncheck.com/xdb	Exploit intelligence reference.
Rejetto HFS project	https://github.com/rejetto/hfs	Upstream project and release reference.

Confidence is ****medium**** unless a cited primary source states confirmed exploitation, victim impact, or attribution. This report avoids inventing IOCs, victim counts, attribution, malware samples, or exploit mechanics not present in public sources.

4. Threat / Campaign Details

The reporting is relevant because defenders are managing a compressed decision window: public advisories, ransomware operations, social engineering, AI-enabled abuse, supplier dependencies, and remote-access exposure can become operational incidents quickly. The appropriate response is to translate the reporting into exposure review, detections, hunts, and prioritized owner actions.

5. Attack Scenarios

Scenario	Description	Defensive Priority
----------	-------------	--------------------

Opportunistic exploitation or phishing	Adversaries use current lures, exposed services, or known weaknesses to gain access.	Patch, harden identity, and validate email/web controls.
Targeted access	A focused actor targets high-value users, suppliers, or operators with tailored tradecraft.	Prioritize VIP/admin monitoring and supplier access review.
Post-compromise expansion	Initial access is followed by credential theft, lateral movement, tool staging, or ransomware preparation.	Hunt process, identity, network, and data-staging signals.

6. Affected Sectors and Exposure

Exposure Pattern	Why It Matters	Immediate Check
Public-facing systems	High discovery rate and common initial access path.	Confirm patch and internet exposure status.
Identity and remote access	Enables stealthy follow-on access after initial compromise.	Review MFA, new devices, risky sign-ins, token creation, and privileged changes.
Supplier connectivity	Third parties can become trusted paths into sensitive environments.	Validate access scope, logging, and incident notification.
Endpoint scripting and admin tools	Common in hands-on-keyboard activity.	Alert on abnormal shell, PowerShell, RMM, and archive-tool use.

7. Detection Engineering

7.1. Detection Logic Summary

Signal	Telemetry Source	Analytic Goal
Browser, email, web, or collaboration process spawning script/transfer tooling	EDR process telemetry	Detect follow-on activity after exploitation or lure execution.
New outbound connections from unusual hosts	Network/EDR telemetry	Identify payload retrieval, C2, or data staging.
Abnormal identity activity	Entra ID/Okta/VPN logs	Catch token theft, MFA changes, impossible travel, or admin role changes.
New persistence or remote access tooling	EDR, Windows events, package manager logs	Identify durable footholds.

```

title: LBC Daily Threat Suspicious Follow-On Activity - daily-2026-10-06-rejetto-hfs-cve-2026-61500-
exploitation-and
status: experimental
logsource:
  product: windows
  category: process_creation
detection:
  suspicious_parent:
    ParentImage|contains:
      - "\w3wp.exe"
      - "\httpd.exe"

```

```

- "\nginx.exe"
- "\chrome.exe"
- "\msedge.exe"
- "\outlook.exe"
- "\teams.exe"
suspicious_child:
  Image|endswith:
    - "\cmd.exe"
    - "\powershell.exe"
    - "\pwsh.exe"
    - "\rundll32.exe"
    - "\certutil.exe"
    - "\curl.exe"
    - "\wget.exe"
    - "\7z.exe"
  condition: suspicious_parent and suspicious_child
fields:
- UtcTime
- Computer
- ParentImage
- Image
- CommandLine
level: high

```

8. Threat Hunting

8.1. Microsoft Defender / KQL Hunt

```

DeviceProcessEvents
| where Timestamp > ago(14d)
| where InitiatingProcessFileName in~ ("w3wp.exe", "httpd.exe", "nginx.exe", "chrome.exe",
"msedge.exe", "outlook.exe", "teams.exe")
| where FileName in~ ("cmd.exe", "powershell.exe", "pwsh.exe", "rundll32.exe", "certutil.exe",
"curl.exe", "wget.exe", "7z.exe")
| project Timestamp, DeviceName, InitiatingProcessFileName, FileName, ProcessCommandLine, AccountName

SigninLogs
| where TimeGenerated > ago(14d)
| where ResultType == 0
| summarize Countries=make_set(Location, 10), Apps=make_set(AppDisplayName, 20), count() by
UserPrincipalName, bin(TimeGenerated, 1d)
| where array_length(Countries) > 2 or count_ > 20

DeviceNetworkEvents
| where Timestamp > ago(14d)
| where InitiatingProcessFileName in~ ("powershell.exe", "pwsh.exe", "curl.exe", "wget.exe",
"python.exe", "node.exe")
| summarize Connections=count(), RemoteUrls=make_set(RemoteUrl, 20) by DeviceName,
InitiatingProcessFileName, bin(Timestamp, 1d)
| where Connections > 25

```

9. MITRE ATT&CK Mapping

Technique	Name	Evidence / Rationale
T1566	Phishing	Relevant for lure-driven initial access and credential theft.
T1190	Exploit Public-Facing Application	Relevant where exposed services or advisories drive risk.
T1078	Valid Accounts	Supplier and identity abuse are recurring follow-on paths.
T1059	Command and Scripting Interpreter	Common execution behavior after

		compromise.
T1105	Ingress Tool Transfer	Payload/tool retrieval and staging.

10. Incident Response and Containment

Phase	Action
Triage	Identify exposed assets, affected users, supplier links, and relevant telemetry windows.
Containment	Disable suspicious sessions, isolate affected hosts, apply patches, and restrict risky access paths.
Eradication	Remove unauthorized tooling, rotate secrets, and validate persistence locations.
Recovery	Confirm business process resilience, backups, and monitored restoration.

11. Recommendations

Priority	Owner	Action
Today	SOC	Run the included hunts across 14 days of endpoint, identity, and network telemetry.
Today	IT / platform	Confirm patching and exposure for systems implicated by the reporting.
24-72 hours	IAM	Review privileged accounts, MFA changes, new devices, and risky sign-ins.
7 days	Risk / vendor management	Request supplier attestations for relevant exposure and incident notification.

12. References

- [1] SecurityWeek Rejetto HFS exploitation coverage: <https://www.securityweek.com/exploitation-hits-rejetto-hfs-vulnerability-discovered-by-ai/>
- [2] GitHub CVE-2026-61500 proof-of-concept repository: <https://github.com/aramosf/CVE-2026-61500>
- [3] VulnCheck XDB: <https://vulncheck.com/xdb>
- [4] Rejetto HFS project: <https://github.com/rejetto/hfs>
- [A] CISA Known Exploited Vulnerabilities Catalog: <https://www.cisa.gov/known-exploited-vulnerabilities-catalog>
- [B] CISA Cross-Sector Cybersecurity Performance Goals: <https://www.cisa.gov/cross-sector-cybersecurity-performance-goals>
- [C] MITRE ATT&CK Enterprise Matrix: <https://attack.mitre.org/>